



外部攻击面管理服务白皮书

亚信科技（成都）有限公司

2023 年 10 月

目 录

1. 背景	1
1.1 网络安全态势	1
1.2 监管要求与合规性	1
1.3 企业风险管理现状	1
1.4 亚信安全推出攻击面管理服务	2
2. 服务介绍	2
2.1. 服务全景	2
2.2. 服务内容	3
2.2.1. 多维度梳理外网资产，建立资产台账	3
2.2.2. 多平台检测泄密信息，形成有效信息库	4
2.2.3. 漏洞验证，及时发现可被利用攻击面	5
2.2.4. 多元化识别暴露风险 提升抗攻能力	6
2.3. 服务场景	6
2.3.1. HVV/重保前风险排查	6
2.3.2. 企业日常持续化安全运营	6
2.3.3. 监督管理场景	6
2.4. 服务交付	7
2.4.1. 交付流程	7
2.4.2. 交付内容	8
2.4.2.1. 门户	8
2.4.2.2. 报告	8
2.4.2.3. 专家解读	9
3. 产品优势	9
3.1. 技术核心优势	9
3.2. 特色功能优势	9

3.3. 服务交付优势 10

4. 客户价值 10

1. 背景

1.1 网络安全态势

随着互联网的飞跃式发展，企业信息化建设的力度持续增强，企业业务不断拓展，各单位纷纷增设分支机构、增加供应厂商。在扩大组织规模的同时，其泛资产数量呈爆发式增长，导致所属资产来源广泛、覆盖面大、边界不清，极易被攻击者利用成为新的攻击触点。因此，组织必须加强对不断增长的外部攻击面的管理，以确保企业的信息安全和稳定运营。

其次，随着网络空间军事化进程的加速，犯罪参与者利用互联网的开放性和联通性技术特性，通过外部威胁和漏洞的变化，从外部侵入内部，控制重要设施，窃取机密情报。这种行为对国家安全，特别是关键信息基础设施安全构成了极大的威胁。因此，外部攻击面成为国家、政府、企业关注的重点。

1.2 监管要求与合规性

根据 2022 年 10 月 12 日国家市场监督管理总局和国家标准化管理委员会正式发布《信息安全技术-关键信息基础设施安全保护要求》。明确指出要围绕关键信息基础设施承载的关键业务，开展业务依赖性识别、关键资产识别、风险识别等活动。同时要求以应对攻击行为的监测发现为基础，开展互联网暴露面治理，全面了解互联网暴露面，并收敛暴露面。

此外，国务院在《关于加强数字政府建设的指导意见》中强调了提升数字政府网络安全整体保护能力和水平的重要性。为了落实重要保护措施，应采取科学的技术应对措施，包括集中化、集约化建设网络应用，治理互联网暴露面，采取纵深防御措施，加强精准防护，及时发现、捕获和阻断攻击，并提升技术对抗能力。

1.3 企业风险管理现状

随着业务的快速发展和数字化转型的推进，传统的资产管理面，如基于 IP、域名、端口、服务的安全管理，已经无法适应当前复杂多变的网络安全环境。在新的环境中，未知资产、影子资产、泄露的数据、分子公司、供应链/第三方、云安全等都可能成为攻击者的突破口。企业在日常的安全风险管理中，通常面对以下痛点：

1. 人为的无意识或有意识的威胁，最薄弱环节

内部人员主动上报意识薄弱，例如存在资产未被收录、管理存在盲区、为追求快速上线而未进行安全检查、未纳入安全管控等问题。同时，外部人员也可能存在操作上的问题，例如在公有云场景下，IP 地址动态分配，但 DNS 解析 A 记录未能及时更新。

2. 资产情况难掌控，困扰企业安全人员

影子资产及子公司资产的发现及监管存在一定的难度；旧版本的 APP 容易遭到脱壳反编译，存在恶意攻击风险；云上资产使得企业边界变得模糊，增加了资产管理的难度；资产变更频率高，攻击面风险也在持续动态变化，企业缺乏统一、动态的外部攻击视角。

3. 第三方供应链安全，容易被攻方利用

即使企业在保障自身的安全情况下，也难以确保供应链不会带来风险。在复杂多变的网络环境下，供应链可能存在安全风险，例如企业某供应链开发的软件存在漏洞，攻击者可能利用此漏洞获取企业服务器的权限；企业某供应链开发的测试环境未下线，其登录密码可能未进行加密处理；企业某供应链系统的代码托管平台存在代码泄露，导致系统被攻破。

4. 数据泄露，容易被社攻且影响企业声誉

在主流的网盘、文库及代码托管平台上存在大量的：账号密码或配置文件泄露、敏感接口地址泄露、系统平台架构信息泄露等信息，该类数据分布零散且无规律，管理无抓手。

1.4 亚信安全推出攻击面管理服务

亚信安全在服务国内企业的过程中发现，无论企业怎么做漏洞扫描、渗透测试，甚至是众测，依然会被攻击者发现未知资产，并利用漏洞突破防御。根据这一现状，结合 Gartner 提出的“攻击面管理”概念，亚信安全推出了“攻击面管理服务”，致力于为企业提供一个外部视角，帮助企业从外部向内看清自身资产情况，先攻击者一步发现自身未知资产与威胁，实现动态的主动防御。亚信安全拥有国内一流的红队，成员平均从业经验 8 年以上，拥有成熟的资产梳理思路与攻击方法论，能够赋能于攻击面管理平台，让企业真正的了解自身外部攻击面情况。

2. 服务介绍

亚信安全外部攻击面管理服务，旨在帮助企业站在攻击者的视角，以攻促防，帮助客户不断收敛影子资产、数据泄露等未知风险，助力实现从“被动防御”向“主动防御”的进阶。

此外，提供攻防专家对交付结果进行评估，保障结果的高可靠性、高可读性，针对异常资产提供下架服务，可对发现的暴露点进行快速处置，做到真正的风险发现、风险分析、风险处置闭环。

2.1. 服务全景

亚信安全的攻击面管理平台能够依托外部攻击面管理（EASM）技术，基于企业股权关系、供应链、业务系统、邮箱账号、APP 应用、公众号小程序、网盘文库、代码托管平台、子域名、全端口等信息，对企业外部攻击面进行全面的发现，并在发现的基础上，继续深入，对企业攻击面进行高危路径、高危端口、高危漏洞、弱口令、历史密码泄露验证，同时结合漏洞可利用性、漏洞影响性对弱点/漏洞进行优先级评估，向企业输出可用性安全运营指标，帮助持续管理安全态势，强化自身网络安全防御体系。

解决问题	1. 补充客户外部防御视角； 2. 对客户影子资产进行发现验证； 3. 帮助客户明确自身边界； 4. 及时发现企业数据泄露风险		
客户画像	集团型客户总部的信管部门	近期发生过网入侵类安全事件的客户	参加HVV的客户
应用场景	企业安全运营	事后风险盘点	HVV/重保前风险排查
服务内容 及价值	互联网资产暴露面梳理 知己 ，深度洞察企业自身资产暴露和数据泄漏情况， 补齐攻防视角差异		商业泄密风险检测 知彼 ，先于攻击者发现攻击面风险，根据风险优先级治理， 提升实战对抗能力
服务优势	差异化服务，更有竞争力： ✓ 将EASM融入HVV解决方案 ✓ 具有自研服务支撑平台 ✓ 30分钟内自动完成检测及报告	实战化，深度、维度均超其他友商： ✓ 检测维度20+ ✓ 同纬度数据远超友商 ✓ 帮助客户更全面发现自身外部攻击情况	体系化，较于传统梳理，服务更标准： ✓ 支持持续暴露面管理(CTEM)全流程 ✓ 覆盖外部攻击面管理(EASM)、漏洞评估(VA)、弱点/漏洞风险优先级(VPT)等新技术

2.2. 服务内容

2.2.1. 多维度梳理外网资产，建立资产台账

现代企业通常面临数字化转型快、云基础设施杂而多、分子公司多但管辖权力低、业务变动快、并购资产及供应商/第三方安全能力参差不齐的情况。复杂的组织关系、业务及技术体系，使得企业的攻击面在不断扩大，防守难度指数级增加。看得见，成为企业网络安全防护的基础，能见度越高，企业才能越安全。

1. 组织结构信息收集

互联网收口将基础设施变成一张网，二级单位多是接入总部，但往往下级单位是攻击薄弱点，本次梳理，将优先面向多渠道梳理组织结构及其股权分配情况，其次把包含子公司在内的所有数字资产纳入梳理范围。

2. 域名资产收集

针对域名资产的收集需要运用多种渠道，如域名信息备案系统、各级单位登记的官网；针对子域名的收集可利用资产测绘系统、子域名爆破字典或利用一些常用工具进行子域名收集，如 OneForAll。

3. IP 资产收集

基于已知 IP、域名、ICON、网页标题等作为线索，使用红队专用字典，在主动探测的基础上，同时利用 **Passive DNS** 数据进行被动检测，模糊匹配相关联 IP 资产，逐项验证，可发现一些钓鱼/仿冒站点、主机端口开放较多、未知影子资产、供应链测试资产或一些网站泄露信息等安全风险

4. 云资产收集

业务上云趋势，网络安全边界模糊，梳理云资产也是关键一步，可基于 IP 地理位置及其运营归属定位云上资产

5. 数据库资产收集

基于梳理的资产信息，如端口、协议、标题等信息，发现暴露在互联网侧的数据库资产信息，包括：IP、端口、数据库类型、数据库版本等。

6. 移动应用收集

传统 WEB 攻击方式已经很难取得正面突破，攻击方愈发重视 APP、公众号、小程序此类移动应用的攻击，比如通过旧版本的 APP 有时很容易脱壳反编译代码。移动应用的收集可通过关键字围绕企业主体、开发者名称、名称或简介几个维度模糊检索。APP 收集渠道是各应用商店或一些数据开发平台，公众号和小程序主要通过微信。

7. 供应链信息收集

全球化背景下，政策持续出台，供应链行业重要性愈发凸显，对于供应链信息的收集主要是通过企业名称对暴露在互联网上的供应数据进行全面检索，如：企业上下游的供应关系、供应商、供应信息等。

8. 邮箱资产收集及泄露判断

为防范中招钓鱼邮件，除通过对暴露在互联网上的邮箱账号进行检索外，还综合暗网数据判断邮箱账号是否被泄露。

2.2.2. 多平台检测泄密信息，形成有效信息库

安全防护中最薄弱的环节是人，为了防止被社工攻击者抓住某泄露弱点，本次泄密信息的发现首先需尽可能全面的覆盖互联网信息渠道，其次需要进行过滤优化、分类汇总，建立有效敏感信息库；最后逐项精确分析可利用思路和攻击链。

1. 尽可能全面覆盖，建立疑似敏感信息库

根据企业简称、业务名称、关键供应链系统名称等作为关键词，对国内主流 10 家网盘、28 家文库、7 家代码托管平台进行逐词模糊检测，尽可能全面的检索相近信息，建立疑似库。

2. 自定义降噪规则，形成有效敏感信息库

基于风险暴露周期、可利用性、影响范围几个关键指标，每个关键字自定义降噪规则，对疑似泄露数据进行自动截图和降噪，大约可处理掉 70% 非本企业或非泄露数据，进而形成有效库。

2.2.3. 漏洞验证，及时发现可被利用攻击面

在完成攻击面发现之后，亚信安全的攻击面管理平台，会对企业所属资产进行高危路径、高危漏洞、弱口令等方面的验证，帮助企业及时发现可被利用的攻击面。

1. 高危端口识别

亚信安全的攻击面管理平台，能够对常见的高危端口进行验证，同时支持企业自定义高危端口字典。

2. 高危路径识别

亚信安全的攻击面管理平台，在验证高危路径时，会基于“北极狐高级攻防实验室”赋能的精细化网站目录字典，结合启发式动态爬虫进行，保障更高覆盖面的同时，能够降低因安全工程师个人因素导致的效果不可靠问题。

3. 高危漏洞识别

亚信安全的攻击面管理平台，内置了 3000 个高危漏洞。漏洞由“北极狐高级攻防实验室”基于攻防经验筛选而出，来源包括 CVE、CNVD、OWASP、安全社区等。同时“北极狐高级攻防实验室”会基于亚信安全漏洞库、亚信安全威胁情报库，定期更新漏洞信息。

4. 弱口令识别

亚信安全的攻击面管理平台，内置了“北极狐高级攻防实验室”沉淀的弱口令字典，且支持用户自定义弱口令字典，能够精确智能的识别超过 18 种协议服务的弱口令，包括：

MySQL、Oracle、MSSQL、MongoDB、PostgreSQL、Redis、MemCache、

FTP/VsFTP/ProFTPD、Subversion、SMB、SMTP、POP3、IMAP、LDAP、PPTP、OpenVPN、OpenSSH、RDP:3389。

2.2.4. 多元化识别暴露风险 提升抗攻能力

基于泄密信息检测及互联网资产梳理的多元化关联结果，安全专家凭借多年的攻防实践经验，以及自动化工具，进一步逐项开展风险评估，并提供整改优先级指导建议，关注其处置状态，跟踪管理闭环。如针对影子资产，识别确认后审计其日志，查看是否存在被攻击的情况，并检查相关防护情况进行安全加固；如针对账号密码或配置文件泄露，及时联系修改账号密码或配置信息，检查是否存在异常活动或未授权访问，同时联系相关平台进行下架等。

2.3. 服务场景

2.3.1. HVV/重保前风险排查

在 HVV/重保的前期阶段，由于时间紧迫，要在短时间内摸清企业所有的资产并排查可能存在的风险，是一项极具挑战性的任务。传统的人工排查方法需要投入大量的时间和资源，且可能存在排查不全面、不深入以及外部资产探测不明确等问题。星海平台凭借其 SaaS 化平台，拥有百亿数据库和数万条决策规则，能够高效、快速、准确地收集、筛选和分析外部攻击面。此外，亚信安全作为业内首家将外部攻击面服务全面融入 HVV/重保解决方案的公司，覆盖了 20 多个省份，涵盖金融、电力、政企等多个领域，具有丰富的实践经验，可提前“以攻促防”，主动发现边缘资产、影子资产，梳理风险暴露面，检测资产安全风险，调整安全策略。

2.3.2. 企业日常持续化安全运营

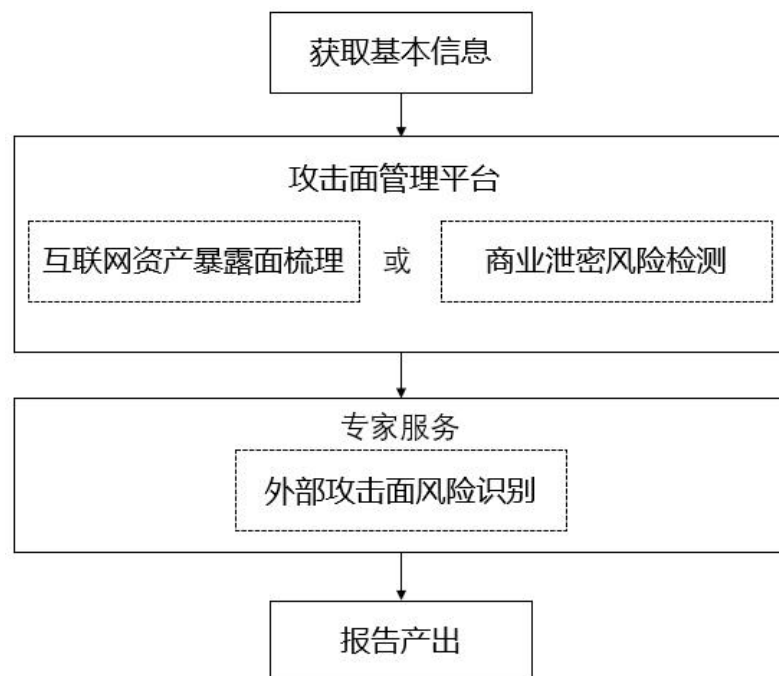
在网络安全形势瞬息万变、高危漏洞频繁出现、网络环境日趋复杂的情况下，企业应不断加强自身的安全防御能力。安全无小事，需要定期对企业安全进行全面排查。企业在日常运营过程中，应以攻击者的视角，持续关注暴露面资产及威胁状况，全面清点和减少未知资产，降低通过网络边界的风险。针对这一问题，星海平台提供一键化操作，对外部攻击面进行搜集、排查、分析、解读，全程管家式服务，同时自带运营门户，实现风险发现、响应、处置的闭环，为客户节省时间、省心省力。

2.3.3. 监督管理场景

随着互联网与信息技术的进步，网络安全问题已成为全球范围内的重点关注议题。网络安全监管工作的开展正在不断加强，企业在遵守相关政策和法律法规的前提下，还应积极履行自身的监管责任，强化自身的网络安全管理，以确保自身网络系统不会成为安全威胁的源头及传播途径。星海平台具备高效发现外部攻击面的能力，可以提前应对可能发生的危险，降低因外部资产安全问题而引发的网络风险，为网络安全监管提供有力支持，降低不合规性，有效防范和化解网络安全风险与威胁。

2.4. 服务交付

2.4.1. 交付流程



1. 获取基本信息

在进行外部攻击面风险识别前，由项目实施人员进行对接，选择外部攻击面风险识别基础服务（互联网资产暴露面梳理服务、商业泄密风险检测服务），并根据基础服务获取基本信息、签订授权书。“基础服务-互联网资产暴露面梳理”需要提供公司全称、一级域名；“基础服务-商业泄密风险检测”需要提供检测关键字，可以是公司全称、简称、一级域名。

2. 通过攻击面管理平台产出基础数据

根据选择的基础服务，利用攻击面管理平台进行自动化发现、梳理产出基础数据，在互联网资产暴露面方面，识别的维度包括股权关系、服务、域名资产、IP 及端口、云资产、数据库、SSL 证书、邮箱资产、公众号、移动应用、供应链；在商业泄密风险检测方面，涵盖 10 家国内主流网盘、28 家国内主流文库、7 家主流代码托管平台。

3. 专家服务分析外部攻击面

由亚信安全专家，基于风险管理成熟度模型，在基础服务数据的基础上，结合影响范围、利用难度等因素，对企业外部攻击面进行分析，并给出综合评定以及修复指导建议。

4. 报告产出

亚信安全专家在完成外部攻击面风险识别结果整合后，将编写《外部攻击面风险识别报告》并交付。

2.4.2. 交付内容

2.4.2.1. 门户

1. 支持独立账号登录门户网站，实现客户对企业资产情况的实时查看，确保全面了解资产状况。
2. 支持审查复核后自行进行外部攻击面扫描，一键式下发任务，可随时随地对企业外部攻击面进行了解，实现省心、省时、省力。
3. 支持报告下载功能，同时提供实时查看外部攻击面管理的可视化分析视图，为客户提供详实的安全数据。
4. 支持运营管理，实现威胁信息的发现、告警和处置的闭环，提升安全事件响应的效率和时效性。

2.4.2.2. 报告

序号	内容	报告名称样例
----	----	--------

1	外部攻击面风险识别服务	《外部攻击面风险识别报告.docx》、《互联网资产暴露面梳理明细表.xlsx》、《商业泄密风险检测明细表.xlsx》
2	互联网暴露面资产梳理服务	《互联网资产暴露面梳理报告.docx》、《互联网资产暴露面梳理明细表.xlsx》
3	商业泄密风险检测服务	《商业泄密风险检测报告.docx》、《商业泄密风险检测明细表.xlsx》

2.4.2.3. 专家解读

1. 提供 7*24 云端攻防专家 1V1 高效响应，各省安服专家面向客户报告解读。
2. 通过深入分析报告，提前识别并防御潜在威胁，为企业的资产部署提供全面的安全预防策略。
3. 针对已出现的安全问题，提供快速、高效的解决方案，帮助客户迅速恢复业务运行，避免损失扩大。专家团队拥有敏锐的洞察力、精湛的技术和丰富的经验，为客户保驾护航。

3. 产品优势

3.1. 技术核心优势

1. 数字资产 丰富全面：构筑完全自主的资产库，百亿级 IP 端口、十亿级域名资产库、千万级的移动应用库等；
2. 泄密检测 全面精准：泄密检测覆盖 10 家网盘、28 家文库、7 家代码托管，支持精准定制化的数据清洗规则；
3. 攻防沉淀 情报加持：高级攻防专家 8 年沉淀与积累成果转化，同时整合多渠道威胁情报，提高情报价值；
4. 多维建模 清洗数据：默认内置多维规则及模型，自动进行数据降噪清洗及风险优先级评估；

3.2. 特色功能优势

1. 企业组织结构自动梳理，各级企业资产全面盘点，同时支持子公司屏蔽
2. 域名、IP、关键字等多维关联，资产来源清晰可见，线索图谱详细定位
3. 商业敏感泄露数据自动化监测，自动采集网页快照，快速定位泄密位置
4. 构建资产台账，同时支持异常资产管理闭环，一站式管理提升运营效率

3.3. 服务交付优势

1. 能力集中 SaaS 交付：安全专家集中云端交付，安全能力在云端集中汇合，客户侧零部署，零运维
2. 云地协同 联合交付：7*24h 云端专家 7*24h 梯队 1V1 响应，31 省安服专家现场服务
3. 报告解读 可信可靠：7*24 云端攻防专家 1V1 高效响应，各省安服专家面向客户报告解读；

4. 客户价值

1. 安全合规护航：为企业提供完备的安全合规解决方案，保驾护航。
2. 智能化降本增益：实施智能化策略，有效降低人力和成本开支。
3. 一站式后勤解决方案：提供一体化服务，全面解决企业后勤管理问题，助力业务高效运营。
4. 专业报告解读：由专业专家解读报告，拒绝信息误导，确保数据可信度。